

Section 12: Test Scenario

AWS IAM & Incident-Response Deep Dive — practical exercise

This is a different environment, different identities, and a different attack path than the svc-prod-backup scenario. No answer key is provided in this document — work through the questions and bring your answers back to the conversation. Answers will be challenged one question at a time, not accepted at face value.

Environment

Contoso Corp, AWS account 222233334444. Known identities: developer msmith; role ci-deploy (assumable via GitHub Actions OIDC federation, used by CI to push builds); role data-ops (broader access to RDS and S3, normally assumed only by two senior engineers via console MFA).

CloudTrail Events

Event 1

```
{
  "eventTime": "2026-08-14T09:02:11Z",
  "eventSource": "sts.amazonaws.com",
  "eventName": "AssumeRoleWithWebIdentity",
  "sourceIPAddress": "140.82.112.3",
  "userAgent": "GitHub-Actions-Runner",
  "userIdentity": {
    "type": "WebIdentityUser",
    "principalId": "repo:contoso/legacy-tools:ref:refs/heads/main"
  },
  "requestParameters": {
    "roleArn": "arn:aws:iam::222233334444:role/ci-deploy",
    "roleSessionName": "gha-run-88213"
  },
  "responseElements": {
    "credentials": { "accessKeyId": "ASIACIEXAMPLE01" }
  },
  "errorCode": null
}
```

Event 2

```

{
  "eventTime": "2026-08-14T09:03:47Z",
  "eventSource": "iam.amazonaws.com",
  "eventName": "UpdateAssumeRolePolicy",
  "sourceIPAddress": "140.82.112.3",
  "userIdentity": {
    "type": "AssumedRole",
    "arn": "arn:aws:sts::222233334444:assumed-role/ci-deploy/gha-run-88213",
    "sessionContext": {
      "sessionIssuer": {
        "type": "Role",
        "arn": "arn:aws:iam::222233334444:role/ci-deploy"
      },
      "attributes": {
        "creationDate": "2026-08-14T09:02:11Z",
        "mfaAuthenticated": "false"
      }
    }
  },
  "requestParameters": {
    "roleName": "data-ops",
    "policyDocument": "{\n\"Version\":\n\"2012-10-17\", \"Statement\": [{\n\"Effect\":\n\"Allow\", \"Principal\": {
  },
  "errorCode": null
}

```

Event 3

```

{
  "eventTime": "2026-08-14T09:04:02Z",
  "eventSource": "sts.amazonaws.com",
  "eventName": "AssumeRole",
  "sourceIPAddress": "140.82.112.3",
  "userIdentity": {
    "type": "AssumedRole",
    "arn": "arn:aws:sts::222233334444:assumed-role/ci-deploy/gha-run-88213"
  },
  "requestParameters": {
    "roleArn": "arn:aws:iam::222233334444:role/data-ops",
    "roleSessionName": "gha-run-88213"
  },
  "errorCode": null
}

```

Event 4

```
{
  "eventTime": "2026-08-14T09:04:55Z",
  "eventSource": "lambda.amazonaws.com",
  "eventName": "CreateFunction",
  "sourceIPAddress": "140.82.112.3",
  "userIdentity": {
    "type": "AssumedRole",
    "arn": "arn:aws:sts::222233334444:assumed-role/data-ops/gha-run-88213"
  },
  "requestParameters": {
    "functionName": "contoso-metrics-sync",
    "role": "arn:aws:iam::222233334444:role/data-ops"
  },
  "responseElements": {
    "functionArn": "arn:aws:lambda:us-east-1:222233334444:function:contoso-metrics-sync"
  },
  "errorCode": null
}
```

Event 5

```
{
  "eventTime": "2026-08-14T09:05:20Z",
  "eventSource": "lambda.amazonaws.com",
  "eventName": "CreateFunctionUrlConfig",
  "sourceIPAddress": "140.82.112.3",
  "userIdentity": {
    "type": "AssumedRole",
    "arn": "arn:aws:sts::222233334444:assumed-role/data-ops/gha-run-88213"
  },
  "requestParameters": {
    "functionName": "contoso-metrics-sync",
    "authType": "NONE"
  },
  "errorCode": null
}
```

Event 6

```
{
  "eventTime": "2026-08-14T09:07:10Z",
  "eventSource": "cloudtrail.amazonaws.com",
  "eventName": "StopLogging",
  "sourceIPAddress": "140.82.112.3",
  "userIdentity": {
    "type": "AssumedRole",
    "arn": "arn:aws:sts::222233334444:assumed-role/data-ops/gha-run-88213"
  },
  "requestParameters": {
    "name": "contoso-org-trail"
  },
  "errorCode": "AccessDenied",
  "errorMessage": "User is not authorized to perform: cloudtrail:StopLogging"
}
```

Work through and answer

1. Initial access hypothesis

What's your leading theory for how this started, and what would you check to confirm or weaken it?

2. Identity chain

Trace it fully, upstream and downstream.

3. Attacker objective

What were they actually trying to accomplish, based on the sequence?

4. Blast radius

What could this identity chain reach, and why — not just “data-ops permissions”?

5. Persistence

What did they establish, and what makes it durable?

6. Containment

Full attack-path scope, not just “kill the session.”

7. Additional telemetry needed

What's missing here that you'd need to confirm or extend this picture?

8. Detection opportunities

What would you build to catch this pattern, and at which point in the chain?

Reminder: bring answer #1 back to the conversation first. Each answer gets challenged before moving to the next question — this is meant to be worked through interactively, not filled out in isolation.